Semana 02 — Custodia de secretos y admisibilidad de la evidencia

Grupo 4 · rol Legal y reporte · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	02 de 10
Fase	1 — Fundamentos, criptografía y marco legal
Grupo	4
Rol	Legal y reporte
Entrega	GitHub, carpeta semana_02/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Verifica que el alcance y la autorización cubran lo ejecutado, anonimiza la evidencia, revisa la cadena de custodia e integra el informe técnico y el resumen ejecutivo.

- Revisar que el alcance y la autorización cubran exactamente lo ejecutado, ni más ni menos.
- Anonimizar la evidencia y verificar la cadena de custodia de cada archivo entregado.
- Integrar informe técnico y resumen ejecutivo, y declarar los límites del trabajo.

2 Qué aporta este rol al entregable

La versión final del informe y la declaración explícita de lo que no se pudo verificar.

3 Ejemplo paso a paso

El rol Legal ordena lo que los demas producen: quien custodia cada secreto, quien puede usarlo, cuanto se conserva y que evidencia seria admisible si el hallazgo termina en un procedimiento.

3.1 Inventariar los secretos del laboratorio

Se listan credenciales, claves y tokens que existen en el entorno, con su soporte y responsable. No se copia su valor en el inventario: se identifica, no se duplica.

```
mkdir -p semana_02/evidencia
docker compose ps --format json > semana_02/evidencia/servicios.json
printf 'inventario de secretos: solo identificadores, nunca valores\n' \
  > semana_02/evidencia/secretos_politica.txt
```

3.2 Definir custodia, rotacion y acceso

Cada secreto tiene un custodio nombrado, una frecuencia de rotacion y una regla de acceso. Un secreto sin custodio es un secreto sin dueño y, por tanto, sin responsabilidad.

3.3 Registrar la cadena de custodia de la evidencia

El formulario anota quien adquiere, cuando, con que herramienta y con que hash. Cualquier transferencia posterior se registra con hora y firma.

```
sha256sum semana_02/evidencia/*.txt semana_02/evidencia/*.json \
  > semana_02/evidencia/custodia.sha256
date -u +%Y-%m-%dT%H:%M:%SZ >> semana_02/evidencia/registro_custodia.txt
id -un >> semana_02/evidencia/registro_custodia.txt
```

3.4 Analizar admisibilidad y tipificar el caso

Se separa lo que se obtuvo con autorizacion de lo que no. La evidencia sin autorizacion no se "arregla" con un informe mejor: se excluye y se explica por que.

3.5 Secreto, custodia y base de la decision

Secreto, custodia y base de la decision

Secreto	Soporte	Custodio	Rotacion	Base de la decision
Credenciales de DVWA	Contenedor del laboratorio	Grupo 2	Por practica	Dato de prueba, no personal
Clave de firma RSA	Archivo local con permisos 600	Grupo 1	Mensual o ante incidente	Autenticidad del entregable
Token de GitHub del grupo	Gestor de secretos del repositorio	Grupo 4	Trimestral	Acceso al repositorio privado
Evidencia de la practica	Carpeta con hashes y registro	Grupo 4	Hasta cerrar el curso	Trazabilidad y cadena de custodia

La columna normativa cita la fuente usada en la semana 3; si el grupo no tiene la norma a mano, escribe "pendiente de verificar" en vez de inventar el articulo.

4 Qué guardar en el repositorio

El informe entrega el inventario, la politica de custodia y rotacion, el registro con hashes y el juicio de admisibilidad del caso, separando hechos de hipotesis.

```
semana_02/
|-- informe.md
|-- evidencia/
|   |-- servicios.json
|   |-- secretos_politica.txt
|   |-- custodia.sha256
|   `-- registro_custodia.txt
`-- README.md
```

- El inventario identifica secretos sin transcribir su valor.
- Cada secreto tiene custodio y frecuencia de rotacion declarados.
- El registro de custodia incluye hash, fecha y usuario que adquirio.
- El juicio de admisibilidad distingue lo autorizado de lo que no lo esta.

5 Cómo se corrige

Criterio	Peso
Cifrado y descifrado correctos con verificación de integridad	3,0
Firma y verificación demostradas, incluido el caso alterado	2,5
Lectura correcta del certificado y de la cadena	2,0
Medición de KDF con conclusión sobre coste y seguridad	1,5
Explicación de qué propiedad cubre cada primitiva	1,0
Total	**10,0**

- No se sube al repositorio ningun valor de credencial, ni siquiera de laboratorio.
- La evidencia sin autorizacion se documenta como excluida, no se intenta justificar.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.